

MY CYBER ACADEMY

Session 2 of 14

CREST Practitioner Intrusion Analyst (CPIA)

Core Technical Skills I: IP Protocols & Network Architectures

The protocols and topologies that carry every intrusion — and that every network-level analysis rests on.

GROUP B | IP PROTOCOLS | ARCHITECTURES

© Billy Forrest

Group B: Core Technical Skills across three sessions

Session	Areas	Focus
2	B1 IP Protocols, B2 Network Architectures	TCP/IP, HTTP(S), DNS, email, cabling, NAT
3	B3–B6 Tools, Fingerprinting & NAC	Tool classes, OS/application fingerprinting, NAC
4	B7–B11 Crypto, Permissions & Host	Crypto, permissions, host analysis, data formats

© Billy Forrest

SESSION OBJECTIVES

By the end of this session you will be able to

- **Compare IPv4 and IPv6** address formats, sizes and address classes
- **Explain TCP, UDP and ICMP** their roles, headers and trade-offs
- **Describe the application protocols** HTTP(S), SMTP, DNS and how the web and email work
- **State the fundamental protocols** IRC, DHCP, FTP, SMB, SNMP and their security implications
- **Recognise network architectures** cabling, domains, NAT, 802.11, VLANs, subnets and routing

© Billy Forrest

Understanding protocols

- **Protocols govern exchange** networking protocols define how systems and devices exchange data
- **SMTP** defines how email applications send email
- **FTP** defines how files are transferred to a server
- **The OSI model** a seven-layer reference model that frames protocol interactions
- **Protocol awareness** is the foundation for reading captures and reconstructing attacks

© Billy Forrest

The Internet Protocol (IP)

- **Routes data** IP routes data from source to destination using special network addresses
- **Unique numerical identifiers** assigned to all devices on the network, e.g. 192.168.10.2
- **Two standards in use** IPv4 and IPv6
- **IPv4** 32-bit address, about 4 billion addresses, split into four sections
- **IPv6** 128-bit address, 2^128 addresses, split into eight sections

© Billy Forrest

IPv4 address classes

Class	Public range	Private range
A	0.0.0.0 – 126.255.255.255	10.0.0.0 – 10.255.255.255
B	128.0.0.0 – 191.255.255.255	172.16.0.0 – 172.31.255.255
C	192.0.0.0 – 223.255.255.255	192.168.0.0 – 192.168.255.255
D	224.0.0.0 – 239.255.255.255	Multicast
E	240.0.0.0 – 255.255.255.255	Reserved

© Billy Forrest

IPv6 addressing

- **128-bit address** vast address space — 2^128 possible addresses
- **Eight sections** an IPv6 address is written as eight groups of hex digits
- **Three categories** unicast, multicast and anycast
- **Zero compression** consecutive zeros are represented with '::'
- **Example** FE80::FFFF:C0A8:0A02 (link-local address)

© Billy Forrest

Unicast, multicast and anycast

Type	Relationship	Meaning
Unicast	One-to-one	Packet delivered to the single network interface with that address
Broadcast	One-to-all	Delivered to every host on the network segment
Multicast	One-to-many	Address designates a subset of hosts that joined the group
Anycast	One-to-nearest	Delivered to the nearest interface that is part of the group

© Billy Forrest

Internet Control Message Protocol

- **Error reporting and diagnosis** ICMP provides error-reporting and helps solve network problems
- **Used by ping** echo request/reply underpins connectivity testing
- **Attacker abuse** attackers use ICMP to launch Denial-of-Service (DoS) attacks
- **Smurf-style floods** broadcast amplification and ping floods are ICMP-borne
- **Analyst value** ICMP in captures can reveal probing, reachability and covert channels

© Billy Forrest

Transmission Control Protocol

- **Works alongside IP** TCP sends packets to other network devices reliably
- **Three-way handshake** SYN, SYN-ACK, ACK establishes a connection
- **Packets** data is divided into packets for transmission
- **Checksums** ensure data is not corrupted in transit
- **Sequence numbers** detect loss and rebuild data in the correct order

© Billy Forrest

Common uses of TCP and the UDP contrast

Protocol	Reliability	Common uses
TCP	Reliable: handshake, checksums, sequencing	HTTP(S) port 80/443, FTP 20/21, SMTP 25
UDP	Unreliable: no error detection, no sequencing	Online gaming, media streaming, VoIP

© Billy Forrest

Domain Name System

- **Maps names to addresses** www.cybercoaching.com = 198.185.159.145
- **Hierarchical, distributed database** no single server holds all records
- **Query types** DNS lookups and reverse DNS lookups
- **Used by many applications** web browsers, email and utilities such as ping
- **Resolution order** host file → local/internal DNS → public DNS (ISP)

© Billy Forrest

Hypertext Transfer Protocol

- **Web protocol** exchanges information while browsing the World Wide Web
- **Runs over TCP/IP** port 80 by default
- **GET** retrieve HTML documents, scripts and images
- **HEAD** retrieve meta-information in the response headers
- **POST** send data from web pages such as login forms
- **Response codes** 401 Unauthorised, 404 File not found, 500 Internal server error

© Billy Forrest

The Internet, the WWW, and email

- **Internet vs WWW** the Internet is the network of networks; the WWW is the collection of hypertext documents and media
- **Browsing** the browser resolves DNS, opens a TCP connection and issues HTTP requests
- **Send email** SMTP (Simple Mail Transfer Protocol) on port 25
- **Retrieve email** POP (Post Office Protocol) on port 110, or IMAP on port 143
- **Analyst relevance** Trojan malware commonly uses HTTP(S), SMTP and DNS for command and control

© Billy Forrest

IRC, DHCP, FTP, SMB and SNMP

Protocol	Purpose	Security note
IRC	Messaging and data-file exchange between users	Often abused for botnet command and control
DHCP	Automatically assigns IP configuration to devices	Rogue DHCP can redirect traffic
FTP	Transfers files; ports 20 (data) and 21 (control)	Unencrypted — credentials sent in clear
SMB	Shares files, printers and ports on a LAN; port 445	Historically vulnerable; 'Shares' are key evidence
SNMP	Monitors and manages network devices	'A gold mine for hackers' — information gathering

© Billy Forrest

DISCUSSION

Why would an intruder prefer to tunnel command and control over HTTP(S) or DNS rather than a dedicated IRC channel?

Think about which ports a firewall and an analyst are most likely to allow out, and how the traffic looks inside an HTTP session.

Encrypted and web-looking channels blend into normal traffic, frustrating detection.

© Billy Forrest

Network architectures you will encounter

- **CAT 5/6 and fibre** the physical layer fundamentals of every network
- **10/100/1000baseT** twisted-pair Ethernet speeds over IEEE 802.3
- **Windows domains** central directory service with domain controllers
- **NAT** Network Address Translation to reuse IP addresses
- **802.11 wireless** Wi-Fi standards across 2.4 GHz and 5 GHz
- **VLANs, subnets, routing** segmentation and the path packets take

© Billy Forrest

CAT 5/6 and Ethernet

- **CAT 5** ANSI/TIA/EIA-568-A with clarification in TSB-95; 8P8C (RJ45) connectors
- **Termination** T568A or T568B wiring schemes
- **CAT 6** Gigabit Ethernet (1 Gbps), backwards compatible, faster performance
- **Reduced length** CAT 6 is limited to 100 metres
- **10/100/1000baseT** 10, 100 and 1000 Mbps over twisted pair (IEEE 802.3)

© Billy Forrest

Fibre optic cabling

Type	Characteristics	Typical use
Single-mode	Carries a single wavelength of light; long distances (~40 km); up to 100 Gbps	WAN bearers, submarine cables
Multi-mode	Carries multiple wavelengths; cheaper than single-mode	100 Mbps (2 km), 1 Gbps (1 km), 10 Gbps (550 m)

© Billy Forrest

Windows domains and NAT

- **Windows domain** a central database/directory service managing a set of resources
- **Domain controllers** authenticate users and enforce policy
- **NAT** first defined in RFC 1631 as a short-term fix for IP address depletion
- **Address reuse** only a subset of internal addresses need translation when talking outside
- **NAT architectures** full cone, address-restricted cone, port-restricted cone, symmetric

© Billy Forrest

802.11 wireless LANs

- **Standards** 802.11 a/b/g/n across 2.4 GHz and 5 GHz (others exist)
- **New naming** 802.11b=Wi-Fi 1, 802.11a=Wi-Fi 2, 802.11g=Wi-Fi 3, 802.11n=Wi-Fi 4, 802.11ac=Wi-Fi 5, 802.11ax=Wi-Fi 6
- **Shared media concerns** copyright, theft, synchronisation and infection on shared media
- **VLANs** data-link-layer segmentation providing security and traffic management
- **Analyst value** rogue access points and weak wireless crypto are common findings

© Billy Forrest

IP subnets and routing

- **Subnet** an identifiable separate part of a network
- **Subnet mask** separates the network portion from the host portion
- **IPv4 subnets** 32-bit addresses; IPv6 uses 128 bits
- **IP forwarding algorithm** determines how packets are routed across interconnected networks
- **Routing protocols** BGP, IS-IS, OSPF, and RIP (15 hops maximum)

© Billy Forrest

B1 and B2 at a glance

Ref	Topic	Core idea
B1	IP Protocols	IPv4/IPv6, TCP/UDP/ICMP, HTTP(S), SMTP, DNS, IRC/DHCP/FTP/SMB/SNMP
B2	Network Architectures	CAT5/6, fibre, domains, NAT, 802.11, VLANs, subnets, routing

© Billy Forrest

KEY TAKEAWAYS

- **IP has two flavours** IPv4 (32-bit, four sections) and IPv6 (128-bit, eight sections)
- **TCP is reliable, UDP is fast** handshake, checksums and sequencing versus no guarantees
- **Web and email** HTTP(S) port 80/443; SMTP 25 send; POP 110 / IMAP 143 retrieve
- **Protocols are attack surfaces** IRC, DHCP, FTP, SMB and SNMP are commonly abused
- **Architectures shape analysis** cabling, domains, NAT, wireless, VLANs, subnets and routing

© Billy Forrest

QUIZ

Consolidation quiz (B1 · B2)

- Which protocol uses a three-way handshake to establish a connection?
- An IPv6 address is how many bits long?
- Which protocol sends email on port 25?
- What does the subnet mask separate?
- Which routing protocol is limited to 15 hops?

Answers in the session quiz — aim for 70%+ before leaving.

© Billy Forrest

NEXT SESSION

Next session: Core Technical Skills II

- Common classes of tools: network monitoring, memory acquisition, forensic analysis
- OS fingerprinting: passive techniques and tools such as p0f and NetworkMiner
- Application fingerprinting: metadata, banners, user-agent strings, email headers
- Network Access Control (NAC) analysis

Reading: Knowledge Group B source material — areas B3 to B6.

© Billy Forrest



MY CYBER ACADEMY

Session 3 of 14

CREST Practitioner Intrusion Analyst (CPIA)

Core Technical Skills II: Tools, Fingerprinting & Network Access Control

The tools of the trade, how to identify a target's operating system and applications from evidence, and the role of network access control.

GROUP B TOOLS FINGERPRINTING NAC

© Billy Forrest

Group B continues: tools, fingerprinting and NAC

Area	Ref	Focus
Common Classes of Tools	B3	Network monitoring, memory acquisition, forensic analysis
OS Fingerprinting	B4	Passive/active techniques; p0f, NetworkMiner
Application Fingerprinting	B5	Metadata, banners, user-agent strings, email headers
Network Access Control	B6	Assessing device authentication and posture before network access

© Billy Forrest

SESSION OBJECTIVES

By the end of this session you will be able to

- **Describe the common tool classes** network monitoring, memory acquisition, live collection and forensic analysis
- **Name and compare key tools** Wireshark, NetworkMiner, FTK Imager Lite, Volatility, Memoryze, Autopsy, TSK
- **Explain passive OS fingerprinting** and how packet values reveal the target OS
- **Apply application fingerprinting** via metadata, service banners, user-agent strings and email headers
- **Analyse network access control** device authentication and posture assessment

© Billy Forrest

Common classes of tools

- **Network monitoring** capture and inspect network traffic
- **Memory acquisition** capture volatile memory for analysis
- **Forensic analysis** examine artifacts and reconstruct events
- **These three categories** form the foundation of any intrusion analysis or reverse engineering engagement

© Billy Forrest

Network capturing and monitoring tools

Tool	Description
Wireshark	Free, open source; monitor, capture and analyse network packets
NetworkMiner	Similar to Wireshark; presents data in a human-readable format; adds fingerprinting techniques
MS Network Monitor / Message Analyzer	Microsoft tools to troubleshoot and decipher network protocols; capture, view and analyse data

© Billy Forrest

Memory acquisition tools

Tool	Key features
FTK Imager Lite	GUI-based; acquires physical memory and the pagefile
Volatility	Free, open source; supports 32- and 64-bit systems; acquires and analyses live memory; Windows, Linux and macOS
Memoryze	Free command-line utility; live memory analysis; MemoryDD acquires physical memory, ProcessDD acquires a process address space

© Billy Forrest

Live data collection on Windows (1)

Goal	Command	Purpose
System info	systeminfo	OS details, hardware and network information
User accounts	net user	List all local user accounts
Groups	net group	List groups on a local server

© Billy Forrest

Live data collection on Windows (2)

Goal	Command	Purpose
Processes	tasklist	List the current processes
Ports & processes	netstat -aon	Identify ports and their owning processes
Scripting	PowerShell	CLI and scripting language for admins and power users

© Billy Forrest

Autoruns, opened files and the registry

- **Autoruns** shows automatic startup programs, services and drivers
- **Opened Files View** lists all files currently opened on the system
- **Windows Registry** acquire with FTK Imager Lite, analyse with Registry Browser
- **Persistence insight** startup entries and open files reveal malware footholds

© Billy Forrest

Password recovery and forensic analysis tools

- **Password recovery** recover Windows user account passwords from the SAM and SYSTEM registry files using Ophcrack
- **Autopsy** an open-source forensic analysis tool
- **The Sleuth Kit (TSK)** volume and file system analysis with a plug-in framework
- **Reconstruct events** these tools examine artifacts and rebuild what happened

© Billy Forrest

Passive OS fingerprinting

- **Stealthy capture** stealthily capture network packets to avoid detection
- **Gather intelligence** learn more information about a target without touching it
- **Not 100% accurate** the results provide a foundation rather than certainty
- **Used by attackers too** the same technique feeds reconnaissance

© Billy Forrest

Packet value matching

- **Match known values** passive fingerprinting matches well-known values in packets
- **TTL** time-to-live values differ by OS
- **Window size** TCP window sizes are characteristic
- **Other fields** don't-fragment flag, type of service, presence or absence of options
- **Tool databases** accuracy depends entirely on the signatures stored in the tool's database

© Billy Forrest

The p0f OS fingerprinting tool

- **Developer** Michal Zalewski
- **Platform** Linux, command-line based
- **Capabilities** monitors, captures and examines traffic without sending any packets to the target
- **Command** p0f -i eth0 -p
- **Truly passive** because it sends nothing, it stays stealthy

© Billy Forrest

NetworkMiner as a passive fingerprinting tool

- **Developer** Netresec
- **Platform** Windows, graphical user interface
- **Passive OS fingerprinting** identifies the target operating system from observed traffic
- **Two versions** an open-source version with few limitations and a professional version with additional features
- **Complement to p0f** a GUI alternative for Windows-based analysis

© Billy Forrest

Active versus passive fingerprinting

Aspect	Passive	Active
Traffic sent	None — observes existing traffic	Sends crafted packets to the target
Detection risk	Low, stealthy	Higher — target may notice
Examples	p0f, NetworkMiner passive analysis	Tools that probe and read responses
Analyst use	Safe for sensitive engagements	Useful but noisier

© Billy Forrest

DISCUSSION

In a sensitive engagement where the target must not know they are being assessed, why would you favour passive over active OS fingerprinting?

Think about what an active tool does to the target and what evidence it leaves behind in logs.

Active probing can trip intrusion-detection and leave traces; passive capture avoids both.

© Billy Forrest

Application fingerprinting

- **Identify applications and versions** determine server types and application versions from evidential data
- **Four main methods** metadata, service banners, user-agent strings, email headers
- **Client software** versions identified from metadata within common document types
- **Server software** versions identified from banners and headers
- **Legitimate and illegitimate** the same techniques serve both defence and attack

© Billy Forrest

Document metadata

- **Rich in information** metadata yields extensive application information, often hidden from view
- **Word Metadata Dumper** a Perl script that extracts metadata from Office documents (not the latest formats)
- **DOCX files** latest Office types can simply be extracted with a compression tool
- **app.xml** the docProps\app.xml file holds the application name
- **PDF** pdfinfo is a portable document information extractor for Windows and Linux

© Billy Forrest

Banner grabbing

- **Information-gathering technique** gather the application name and version number
- **Assess security risk** the banner reveals how dated or vulnerable a service may be
- **Example** FTP on an open port returning 'FileZilla 0.9.41 beta'
- **Server identification** banners identify the application, e.g. the web server software

© Billy Forrest

User-agent strings and spoofing

- **Why they exist** browsers advertise themselves so servers can optimise layout, e.g. mobile versus PC
- **Contains system info** the user-agent string includes browser and OS details
- **Easily spoofed** anyone can modify the user-agent to pretend to be another browser or device
- **Content gating** spoofing can reveal content restricted to certain browsers or devices

© Billy Forrest

Email headers

- **Two parts** an email has a header and a body
- **Tracing the sender** headers can be used to trace the location of the sender
- **Basic fields** FROM, TO, DATE, SUBJECT, CC (carbon copy) and BC (blind copy)
- **Viewing headers** Gmail 'Show original'; Thunderbird 'Message Source'; Outlook 'Properties'

© Billy Forrest

Network Access Control (NAC) analysis

- **What NAC does** authenticates and authorises devices before granting network access
- **Posture assessment** checks that a device meets policy (patches, antivirus, compliance)
- **Common mechanisms** 802.1X port-based access control, endpoint agents, RADIUS backends
- **Analyst relevance** assess whether NAC logs capture who and what connected, and any bypass
- **Evidence value** NAC records tie a device identity to a time and place on the network

© Billy Forrest

B3 to B6 at a glance

Ref	Topic	Core idea
B3	Common Classes of Tools	Network monitoring, memory acquisition, live collection, forensic analysis
B4	OS Fingerprinting	Passive packet-value matching; p0f, NetworkMiner
B5	Application Fingerprinting	Metadata, banners, user-agent strings, email headers
B6	Network Access Control	Device authentication and posture assessment

© Billy Forrest

KEY TAKEAWAYS

- **Tool classes** network monitoring, memory acquisition and forensic analysis cover most work
- **Live collection** systeminfo, net user, tasklist and netstat -aon reveal a host's state
- **Passive fingerprinting** p0f and NetworkMiner identify the OS from packet values without sending traffic
- **Application fingerprinting** metadata, banners, user-agent strings and email headers reveal software versions
- **NAC analysis** device authentication and posture logs tie identity to time and place

© Billy Forrest

QUIZ

Consolidation quiz (B3 · B6)

- Which tool acquires physical memory and the pagefile with a GUI?
- Which OS fingerprinting tool sends no packets to the target?
- Where does a DOCX file store its application name?
- Which live-collection command lists current processes?
- What is the core purpose of network access control?

Answers in the session quiz — aim for 70%+ before leaving.

© Billy Forrest

NEXT SESSION

Next session: Core Technical Skills III

- Encryption versus encoding, symmetric and asymmetric ciphers, hashes and HMAC
- Applications of cryptography: SSL/TLS, IPSec, SSH, PGP, WEP and WPA/WPA2
- File system permissions on Windows
- Host analysis techniques and common data formats

Reading: Knowledge Group B source material — areas B7 to B11.

© Billy Forrest



MY CYBER ACADEMY

Session 4 of 14

CREST Practitioner Intrusion Analyst (CPIA)

Core Technical Skills III: Cryptography, Permissions & Host Analysis

The final core-technical session: how cryptography protects data and how it is attacked, what permissions control access, and how to interrogate a live host.

GROUP B | CRYPTOGRAPHY | PERMISSIONS | HOST ANALYSIS

© Billy Forrest

Completing Group B: crypto, permissions, host analysis

Area	Ref	Focus
Cryptography	B7	Encoding vs encryption, symmetric/asymmetric, hashes, HMAC
Applications of Crypto	B8	SSL/TLS, IPSec, SSH, PGP, WEP and WPA/WPA2
File System Permissions	B9	NTFS permissions, ACLs, ownership and inheritance
Host Analysis Techniques	B10	Processes, ports, patch levels, drivers, services, shares
Common Data Formats	B11	Text, binary, timestamps, magic bytes, encodings

© Billy Forrest

SESSION OBJECTIVES

By the end of this session you will be able to

- **Distinguish encryption from encoding** and state the core security services
- **Explain symmetric and asymmetric ciphers** and the algorithms DES, 3DES, AES, RSA, RC4
- **Describe hashes and HMAC** SHA, MD5 and message integrity
- **Apply cryptography in the real world** SSL/TLS, IPSec, SSH, PGP, WEP and WPA/WPA2
- **Analyse file system permissions** and interrogate a live Windows host
- **Recognise common data formats** text, binary, timestamps and encodings

© Billy Forrest

Encryption versus encoding

- **Both transform data** encryption and encoding both change data into another format
- **Both can be reversed** neither is a one-way operation by itself
- **Encoding** transforms data to be used on a different system; not secret; decoding methods are public
- **Encryption** data cannot be used by unauthorised users; relies on secret keys
- **Key distinction** encoding is reversible without a secret; encryption requires a key

© Billy Forrest

Threats and security services

- **Threats** unauthorised access, disclosure and modification of information
- **More threats** misrepresentation of origin, repudiation of a message, replay of a message
- **Cryptography counters threats** the core mechanism against these risks
- **Security services** confidentiality, authentication, integrity, non-repudiation
- **Mechanisms** symmetric ciphers, hashes and MACs, asymmetric ciphers, digital signatures

© Billy Forrest

Symmetric ciphers

- **Confidentiality protection** the primary purpose
- **Same key** the same key value is used to encipher and to decipher
- **Security in the key** assume the attacker knows the system and algorithm — secrecy relies on key protection
- **Random key generation** keys should be generated randomly
- **Examples** DES, 3DES, AES and RC4

© Billy Forrest

Asymmetric ciphers

- **Key pair** a single private key holder but many public key holders
- **Mathematics** relies on factorisation of large primes and elliptic curves
- **Dual purpose** provides both confidentiality and integrity protection
- **Substitution risk** replacing the public key element requires protection
- **Speed** very slow compared with symmetric cryptography

© Billy Forrest

Hash functions and HMAC

- **Hashing equals integrity** a hash verifies data has not changed
- **SHA** Secure Hash Algorithm family
- **MD5** Message Digest algorithm, now considered weak
- **HMAC** a keyed Message Authentication Code providing integrity and authentication
- **Analyst use** hash files to verify evidence integrity during acquisition

© Billy Forrest

Digital signatures and certificates

- **Sign and validate** only one entity can sign with the private key; many may validate with the public key
- **Integrity and non-repudiation** signatures provide both and counter sender denials
- **Certificates** hold public keys and identity, digitally signed by a trusted authority
- **Why certificates** a bare public key is trivial to forge; a certificate ties key to identity
- **Trust** the signing authority is recognised and trusted by the community

© Billy Forrest

Key exchange and management

- **Symmetric key exchange** manual or via PKI techniques
- **Asymmetric key exchange** PKI, often with an LDAP server publishing certificates
- **PGP** Pretty Good Privacy — supports signing and encrypting/decrypting
- **Hybrid use** PGP uses both symmetric and asymmetric ciphers
- **Web of trust** PGP's trust model, distinct from a central CA

© Billy Forrest

Encryption algorithms at a glance

Algorithm	Type	Notes
DES	Symmetric block cipher	Data Encryption Standard; legacy
3DES (TDEA)	Symmetric block cipher	Applies DES three times per block
AES	Symmetric block cipher	Advanced Encryption Standard; substitution-permutation network
RSA	Asymmetric (public key)	Rivest, Shamir and Adleman; factorisation-based
RC4	Symmetric stream cipher	Rivest Cipher 4

© Billy Forrest

Applications of cryptography: SSL/TLS, IPSec, SSH, PGP

- **SSL/TLS** encrypted link between client and server; SSL by Netscape, replaced by TLS
- **IPSec** Internet Protocol Security; end-to-end scheme used in VPNs; transport and tunnel modes
- **SSH** Secure Shell — securely log into another device via a network
- **PGP** encrypt and decrypt email over the Internet; low-cost solution

© Billy Forrest

Wireless encryption: WEP, WPA/WPA2, TKIP

Scheme	Encryption	Notes
WEP	RC4 + CRC-32	Wired Equivalent Privacy; broken — passive/active decryption, injection, dictionary attacks
WPA	TKIP/MIC	Personal uses PSK; enterprise uses 802.1X/EAP
WPA2	AES-CCMP	Personal uses PSK; enterprise uses 802.1X/EAP
TKIP	Temporal Key Integrity Protocol	part of IEEE 802.11i

© Billy Forrest

File system permissions

- **NTFS permissions** control access to files and folders: read, write, execute, full control
- **ACLs** access control lists bind users and groups to allowed actions
- **Ownership and inheritance** permissions inherit down the tree; ownership grants full control
- **Analyst relevance** permissions reveal what an intruder could read, modify or execute
- **Shared vs NTFS** effective access is the intersection of share and NTFS permissions

© Billy Forrest

DISCUSSION

During an intrusion investigation, why does it matter whether the compromised account had write or execute permission on a particular folder?

Think about what an intruder can do with each permission and what it tells you about the impact of the compromise.

Permissions define the blast radius of a compromise and help scope the investigation.

© Billy Forrest

Sockets, ports and processes

- **Sockets and ports** an endpoint of a two-way communication link; a point of entry into a system
- **Multiple connections** a system can hold many simultaneous connections
- **netstat -aon** run as administrator to identify ports and their owning processes
- **tasklist** lists the current processes to cross-reference against netstat output

© Billy Forrest

Assessing patch levels on a Windows host

- **Service packs and hotfixes** not the whole OS receives updates
- **wmic qfe list** use Windows Management Instrumentation to list hotfixes
- **Export to HTML** wmic qfe list brief /format:htable > output
- **DISM** DISM /Online /Get-Packages lists installed packages
- **Patch gaps** missing patches are a common intrusion vector

© Billy Forrest

Drivers, services and network shares

Goal	Command	Purpose
Drivers	driverquery	List the drivers installed on the host
Services	net start	List running services
Shares	net share	List the network shares on the host

© Billy Forrest

Other useful commands

- **systeminfo** OS, hardware and network details
- **net file** shows open files on the network
- **net session** lists active network sessions to the host
- **net accounts** shows account and password policy settings
- **Correlate them** combine these to reconstruct host state and attacker footholds

© Billy Forrest

Understanding common data formats

- **Text vs binary** ASCII/Unicode text versus raw binary structures
- **Timestamps** Unix epoch, Windows FILETIME and log formats need converting to reconstruct timelines
- **Magic bytes / file signatures** the leading bytes of a file identify its true type
- **Encodings** base64 and hex are common in malware and logs
- **Analyst use** identify files and normalise timestamps across evidence sources

© Billy Forrest

CONSOLIDATION · GROUP B

B7 to B11 at a glance

Ref	Topic	Core idea
B7	Cryptography	Encryption vs encoding; symmetric/asymmetric; hashes, HMAC, signatures, certificates
B8	Applications of Crypto	SSL/TLS, IPSec, SSH, PGP, WEP, WPA/WPA2
B9	File System Permissions	NTFS, ACLs, ownership, inheritance
B10	Host Analysis Techniques	Processes, ports, patch levels, drivers, services, shares
B11	Common Data Formats	Text, binary, timestamps, magic bytes, encodings

© Billy Forrest

KEY TAKEAWAYS

- **Encoding vs encryption** encoding is public and keyless; encryption needs a secret key
- **Symmetric vs asymmetric** one shared key versus a private/public key pair
- **Hashes give integrity** SHA, MD5 and HMAC verify data has not changed
- **Crypto in the wild** SSL/TLS, IPSec, SSH, PGP, WEP and WPA/WPA2 protect real traffic
- **Host analysis** netstat -aon, tasklist, wmic qfe, driverquery, net start and net share reveal a host's state

© Billy Forrest

QUIZ

Consolidation quiz (B7 · B11)

- Which algorithm is a symmetric stream cipher?
- What does a hash function provide for evidence?
- Which command lists hotfixes via WMI?
- WPA2 personal mode uses which encryption?
- What do magic bytes identify?

Answers in the session quiz — aim for 70%+ before leaving.

© Billy Forrest

NEXT SESSION

Next session: Background Information Gathering & OSINT

- WHOIS and domain registration lookups
- DNS enumeration and passive DNS
- Search-engine and open-source investigation techniques
- Building a target picture without touching the target

This completes Group B. Next we move to Group C — OSINT.

© Billy Forrest